המסלול האקדמי המכללה למינהל
מדעי המחשב

ת.ז הסטודנט:_____

מס' חדר:_____ מס' נבחן:_____

בחינה בקורס: מבוא לאבטחת סייבר

קוד קורס: 689156

תאריך הבחינה: 31/05/2024 שעת הבחינה: 09:00

שנה"ל: תשפ"ד סמסטר: ב' מועד: א'

מרצה: ד"ר מנחם ליבוביץ

משך הבחינה: 01:20 שעות

הוראות לנבחן:

- מספר השאלות בשאלון: 10
- יש להשיב על כל השאלות
- משקל כל שאלה: 10 נקודות
- הבחינה ללא חומר עזר
- שימוש במחשבון כיס: כן
- מחברת טיוטה: לא
- אין לסמן על דף הקידוד ו/או שאלון הבחינה בַּמַּדְגֵּשׁ (מַרְקֶר) זוהר
- יש לסמן את התשובה הנכונה ביותר בדף הקידוד **בעט שחור/כחול בלבד, באופן ברור ומודגש**
- **רק דף הקידוד ייבדק**
- **חל איסור לתלוש דפים משאלון הבחינה!**
- יש להחזיר את שאלון הבחינה, כולל נספחים (אם קיימים)
- בבחינה זו מתקיים נוהל הוצאת פתקים בשעות: 09:30, 10:00. לזכאי תוספת זמן גם בשעה 10:20

***** חשוב מאוד:**

בדף הקידוד יש לרשום ולקדד את מספר המבחן המופיע בראש הדף בצד ימין (מספר בן 3 ספרות)
יש לרשום את מספר תעודת הזהות במקום המיועד בכתב יד ברור (כולל ספרת הביקורת)

בהצלחה!

בכל השאלות הבאות, התשובה הנכונה היא תשובה מספר 1

שאלה מספר 1:

אליס לקחה plaintext והצפינה אותו, ואז חישבה MAC על ה plaintext. אליס שלחה לבוב את ה ciphertext ואת הtag.

באיזה שיטה אליס עבדה?

1. MAC and Encrypt
2. דיפי הלמן
3. Encrypt then MAC
4. MAC then Encrypt

שאלה מספר 2:

אליס הצפינה בעזרת צופן DES (שגודל הבלוק שלו הוא 8 בתים)

ושיטת הפעלה (mode of operation) של ECB, את הbytes של ה plaintext הבא:

ABCDEFGHABCDEFGH

עם מפתח ההצפנה שמורכב מהbytes של המחרוזת lemonlem.

מה הייצוג ההקסדצימלי של ה bytes של ה ciphertext שיצא לה?

1. 437d7e60707604f3437d7e60707604f3
2. 618142157df60e232e6fea24db009df9
3. 00112233445566778899aabbccddeeff
4. 2e6fea24db009df9ced6000330c42994

שאלה מספר 3:

בטרנזקציה x נעלו את הפלט בעזרת ה output script הבא:

DUP HASH160 [Key Hash] EQUALVERIFY CHECKSIG

מה מבין הבאים הינו input script מתאים שיאפשר לבזבז את ה output script בטרנזקציה עתידית?

1. [Signature] [Public Key]
2. CHECKSIG EQUALVERIFY
3. [Public Key] [Key Hash]
4. [Key Hash] [Public Key]

שאלה מספר 4:

נתון שתוקף הצליח לגנוב את המפתח הפרטי של אתר אינטרנט, אשר משמש אותו להקמת חיבורי TLS עם לקוחות. איזה טענה אינה נכונה?

1. התוקף יוכל לזייף הודעות OCSP (Online Certificate Status Protocol) בשם ה CA שהנפיק את התעודה לאתר האינטרנט.
2. אם לתוקף יש העתק של תקשורת עבר מוצפנת שמבוססת על ה key exchange בין השרת ללקוחות שהתבצע בעזרת RSA עם המפתח שנגנב בהקמת חיבור TLS, הוא יוכל לפענח את התקשורת המוצפנת הזו.
3. תוקף בעל יכולת Man in the Middle יוכל להתחזות לשרת ולהצליח להקים חיבור TLS עם לקוחות כאילו הוא השרת.
4. אם האתר יגלה שהמפתח הפרטי שלו נגנב, הוא יפנה ל CA שהנפיק את התעודה לאתר האינטרנט ויבקש מה CA שיבטל אותה.

שאלה מספר 5:

נתון שרת אשר בונה שאילתא בעזרת המחרוזת הבאה על בסיס ערכי המשתנים ,InputUsername InputPassword, אשר נשלחים לשרת מהדפדפן:

"SELECT * FROM users WHERE username = '" + InputUsername + "' AND password = '" + InputPassword + "'"

איזה ערכים יהוו sql injection תקין?

1. InputUsername = alice, InputPassword = 1234' or '1' = '1
2. InputUsername = alice, InputPassword = 1234' and '1' = '1
3. "InputUsername = alice, InputPassword = 1234' and "1" = "1
4. InputUsername = 'Alice', InputPassword = 1234' or 1 = 1

<u>שאלה מספר 6:</u>

נתון:

- **כתובת ה ip של אליס היא 192.168.0.1 וכתובת ה MAC שלה היא AA:AA:AA:AA:AA:AA**
- **כתובת ה ip של בוב היא 192.168.0.2 וכתובת ה MAC שלו היא BB:BB:BB:BB:BB:BB**
- **כתובת ה ip של התוקף היא 192.168.0.6 וכתובת ה MAC שלו היא 66:66:66:66:66:66**

לאחר שהתוקף ביצע בהצלחה התקפת ARP poisoning

כאשר אליס שולחת הודעה לבוב, לאיזה כתובת ip היא תשלח ולאיזה כתובת MAC?

1. לכתובת ip של 192.168.0.2 ולכתובת MAC של 66:66:66:66:66:66
2. לכתובת ip של 192.168.0.6 ולכתובת MAC של 66:66:66:66:66:66
3. לכתובת ip של 192.168.0.2 ולכתובת MAC של BB:BB:BB:BB:BB:BB
4. לכתובת ip של 192.168.0.6 ולכתובת MAC של BB:BB:BB:BB:BB:BB

<u>שאלה מספר 7:</u>

איזה טענה נכונה?

1. בהודעת ה client finish הלקוח שולח לשרת את תוצאת הפעלת הצפנה ו MAC על ה hash של ההודעות שנשלחו עד כה ב handshake והשרת מפענח ומוודא תקינות עם אותם מפתחות שהקליינט השתמש בהם כדי להצפין ולבצע MAC.
2. בהודעת ה server finish השרת שולח ללקוח את תוצאת הפעלת הצפנה ו MAC על ה hash של ההודעות שנשלחו עד כה ב handshake והלקוח מפענח ומוודא תקינות עם ה public key מהתעודה.
3. לאחר הקמת חיבור ה TLS, ההודעות שהלקוח שולח לשרת לאורך החיבור מוצפנות בעזרת מפתח X (מסויים), והשרת מפענח אותן בעזרת מפתח Y (ששונה מX).
4. לאחר הקמת חיבור ה TLS, ההודעות שהלקוח שולח לשרת לאורך החיבור מוצפנות בעזרת ה public key של השרת בהצפנה א-סימטרית.

שאלה מספר 8:

איזה טענה נכונה?

1. מנגנון Certificate Transparency משתמש בעץ Merkle כדי ליצור שקיפות בהקשר של התעודות ש CAים מנפיקים, ומסייע בזיהוי מוקדם של תעודות זדוניות.
2. מנגנון Certificate Transparency הינו מנגנון המשמש להצפנת חיבורי TLS בין לקוח לשרת בהקשר של שקיפות אלגוריתמי ה cipher suites הנתמכים בין הלקוח לשרת.
3. מנגנון Certificate Transparency הינו מנגנון המשמש להצפנת חיבורי TLS בין שרת לשרת בהקשר של שקיפות אלגוריתמי ה cipher suites הנתמכים בין השרתים ולקוחותיהם.
4. מנגנון Certificate Transparency הינו מנגנון המשמש להצפנת חיבורי TLS בין לקוח לשרת בהקשר של שקיפות אלגוריתמי ה cipher suites המסוכמים בין הלקוח והשרת בהודעות ה server finish וה client finish.

שאלה מספר 9:

איזו מבין הטענות הבאות נכונה?

1. אתר אינטרנט יכול להשתמש ב Content Security Policy (CSP) כדי להגדיר מאיזה כתובות מותר לטעון משאבים כמו קבצי JS שירצו באתר האינטרנט על ידי הדפדפן של הלקוח
2. ב PKI, שרת אינטרנט X שקיבל תעודה חתומה מ CA על ה public key שלו, חייב ש ה CA שנתן לו (ל X) את התעודה יהיה ב root store של הלקוחות
3. ב TLS, שרת האינטרנט מייצר את התעודה עבור חיבור ה TLS
4. על מנת לבצע התקפת ARP poisoning, התוקף זקוק ליכולת Man in the Middle

שאלה מספר 10:

איזו מבין הטענות הבאות נכונה?

1. בביטקוין משתמשים במפתחות א-סימטריים.
2. מגדירים cookies להיות samesite עם הערך strict כאשר רוצים להגדיר את ה HTTP Strict Transport Security (HSTS).
3. מגדירים token להיות samesite עם הערך strict כאשר רוצים להגדיר את ה HTTP Strict Transport Security (HSTS).
4. CAים משתמשים בעץ מרקל כדי שיוכלו לתחזק בעץ את ה hash של הלקוחות הניגשים לתעודות של אתרי האינטרנט.

--- סוף המבחן ---